

Australian Privacy Principles

When someone hands you their personal data, you don't own it — you hold it in trust. The Privacy Act 1988 (Cwlth) sets out 13 Australian Privacy Principles (APPs) that say how organisations must handle that trust. Your study design zooms in on three of them.

What this key knowledge covers

This summary distils everything you need for **KK05 — Australian Privacy Principles** in Data Analysis. Work through the explanations, then use the worked good-vs-weak answers to see exactly how marks are won and lost. Tick off the revision checklist at the end before a SAC or exam.

Study summary

You're not just crunching numbers — you're handling people

In this outcome you **collect, manage and communicate data** to build a visualisation. The moment your dataset contains anything that can be tied back to a real person — a name, a student ID, a survey response, a photo, even a postcode plus a birthday — it becomes **personal information**, and the law has something to say about how you treat it.

That's why the APPs live right here, next to data types and data quality. A brilliant dashboard built on data you collected unlawfully isn't a good solution — it's a liability. The exam expects you to **apply** the three named APPs to the **acquisition, management** and **communication** of data, not just recite them.

Acquisition

How you **collect** the data. Do you need to identify people at all? (APP 2)

Management

How you **use and store** it. Only for the purpose you collected it for (APP 6), and kept secure (APP 11).

Communication

How you **share or publish** findings. Don't disclose beyond the original purpose; protect it in transit (APP 6 & 11).

The Privacy Act 1988 and the 13 APPs

The **Privacy Act 1988 (Cwlth)** is the federal law that protects the personal information of individuals. It contains **13 Australian Privacy Principles (APPs)** — a single set of rules

covering the whole life-cycle of personal information: how it's collected, how it can be used and disclosed, how it must be kept accurate and secure, and a person's right to access it. The **Office of the Australian Information Commissioner (OAIC)** regulates it.

You don't need all 13. The study design names **three**, one for each stage of the data life-cycle:

You are a custodian, not an owner

Here's the mental model that makes the APPs click. Think of personal information like a **coat handed to a cloakroom**.

APP 2 — the masked guest. A guest can attend the event wearing a mask. If the cloakroom doesn't *need* to know who they are to do its job, it shouldn't demand a name. Collect identity only when you truly need it.

APP 6 — the coat is for collecting, not wearing. You handed your coat in for *one* purpose: to get it back later. The cloakroom can't wear it, lend it to a friend, or sell its details to a tailor. Data collected for one purpose can't be quietly repurposed.

APP 11 — the locked back room. While the coat is in their care, it must be kept in a secure room — not left on the front counter for anyone to grab. Reasonable steps to protect what you hold.

Carry this through the whole module: a good **custodian** takes only what they need, uses it only for the agreed job, and guards it while it's in their care.

Non-identification — anonymity & pseudonymity

APP 2 gives individuals the **option of not identifying themselves**, or using a **pseudonym** (a made-up name or code), when dealing with an organisation — *wherever it is lawful and practical*. The default question a custodian should ask is: "**Do I actually need to know who this is to do the job?**" Often, the answer is no.

The survey doesn't need names

PulseCheck is about *patterns across the year level* — average sleep, the spread of screen-time, how stress trends by week. None of that needs Jordan's name attached. So the form collects **anonymous** responses, or at most a **pseudonym/code** (e.g. "respondent 042") if you need to let someone update their own entry.

Primary purpose — use or disclosure

APP 6 says personal information collected for a particular **primary purpose** may only be **used or disclosed for that purpose** — unless an exception applies. The primary purpose is the *main reason you collected it in the first place*. Using it for anything else is a **secondary purpose**, and that needs justification.

What you may do

PulseCheck's primary purpose is **building a wellbeing visualisation for the assembly**. Calculating averages, charting screen-time, and presenting de-identified trends all serve that purpose. Green light.

What needs an exception

Handing the raw "I feel stressed every day" responses to the year-level coordinator to *follow up individual students* is a **different purpose**. It may be defensible, but only via an APP 6 exception — not by default.

The exceptions you can cite

A secondary use/disclosure is allowed when, broadly:

Security of personal information

APP 11 requires an organisation to take **reasonable steps** to protect personal information from **misuse, interference and loss**, and from **unauthorised access, modification or disclosure**. It also says: when you **no longer need** the information, take reasonable steps to **destroy it or de-identify it**.

Where does the spreadsheet live?

"Reasonable steps" scales with how sensitive the data is. PulseCheck stress data is sensitive, so reasonable steps might include: storing the file in the school's **access-controlled drive** (not a shared USB), using **strong passwords / MFA**, limiting who can open it, **encrypting** if exported, and **deleting the raw responses** after the assembly once only the de-identified chart is needed.

Physical

Locked rooms, devices not left unattended, secure disposal of printouts.

Software

Passwords/MFA, access permissions, encryption, up-to-date anti-malware, backups.

Procedural

Who's allowed to access, training, a routine to delete data once it's no longer needed.

The Custodian's Desk

A PulseCheck response just arrived at your desk. Make three custodian decisions and watch the privacy outcome respond live. The 3D shield around the data strengthens or cracks with each choice. Aim for **all three duties green**.

Notice that **each duty is independent**: you can collect perfectly (anonymous) but still fail by selling the data (APP 6) or leaving it in a public folder (APP 11). Compliance is the weakest link, not an average.

Which APP is at stake?

Drag (or tap, then tap a bin) each scenario into the principle it relates to most. Some are deliberately tricky — one is a distractor that isn't really about these three APPs at all.

Named exam traps

These are the specific mistakes that cost marks on APP questions. Learn them as a checklist.

Build a full-mark answer with P·E·L

VCAA rewards structured legal reasoning. Use **P·E·L**: name the *Principle*, give the *Example* from the scenario, then state the *Link* back to the question. Try it below — the checklist lights up as your answer hits each element.

Prompt: "PulseCheck plans to email the full list of named survey responses to a local gym that sponsored the project. Referring to one Australian Privacy Principle, explain why this is a problem." (3 marks)

This breaches **APP 6 (use or disclosure)** of the *Privacy Act 1988* (Cwlth) [Principle]. The responses were collected for the primary purpose of building a wellbeing visualisation for a school assembly; sending named responses to a sponsoring gym is a **secondary purpose** the students did not consent to and would not reasonably expect [Example]. Because no APP 6 exception applies, disclosing the data this way is not permitted and PulseCheck must either obtain consent or only share de-identified results [Link].

VCE-style practice questions

Five questions, 19 marks total, climbing from *define* to *evaluate*. For each: try it, then reveal a **weak** response (with why it loses marks), a **strong** response, and the **marking guide**. Self-mark honestly — it feeds the score dial.

Five-card recap

That single sentence, plus a scenario-specific example for each principle, is a confident full-mark spine for any APP question in this outcome.

Common traps & misconceptions

The re-identification trap

Pseudonymous data can become identifiable when combined with other data. "Year 11 student, plays in the senior netball team, lives in Eltham" might pinpoint one person even with no name. Stripping the name column is **not** the same as making data truly anonymous.

"We already have the data, so we can use it however we like"

Holding data lawfully does **not** grant a free pass to use it for new purposes. The custodian's coat analogy: possession isn't permission. Each new purpose needs consent, a reasonable expectation, or another exception.

Forgetting the "destroy when done" half

APP 11 has two halves. Students remember "protect it" but forget "**get rid of it when you no longer need it**". Keeping raw personal data forever is itself an APP 11 failing.

T1 Listing all 13 APPs

You only need **APP 2, 6 and 11**. Reciting the full list wastes time and signals you don't know which ones the course examines.

T2 Naming the principle but not applying it

"This relates to APP 11" earns little. You must say *what reasonable step applies to this scenario* and *why*. Apply, don't label.

T3 Confusing APP 2 with APP 11

Anonymity (don't collect identity) is **not** security (protect what you did collect). "Make it anonymous" is not an answer to a "how do you secure it" question.

T4 Treating de-identification as bullet-proof

Removing names doesn't guarantee anonymity — re-identification from combined fields is a real risk (APP 2 nuance).

T5 "We own it so we can use it"

Lawful possession ≠ permission for new purposes (APP 6). Each secondary purpose needs consent or another exception.

T6 Forgetting "destroy when no longer needed"

APP 11 is protect *and* dispose. Keeping personal data indefinitely is a breach in itself.

T7 Saying "it's illegal" with no source

Anchor your answer in the *Privacy Act 1988* (Cwlth) and the specific APP. Vague "you can't do that, it's against privacy" loses the legal-reasoning marks.

How to answer exam questions

Read the **command word** first — it sets how much to write. *State/Identify* wants a word or phrase; *Describe* wants features; *Explain* wants reasons and links; *Justify/Evaluate* wants a judgement backed by evidence. Always pull in the **scenario detail** rather than answering in the abstract. The examples below contrast a weak response with a strong one for the same question.

Q1. Define · 2 marks

State what the *Privacy Act 1988* (Cwlth) protects, and name the set of principles it contains.

✗ A weak answer

"It protects your privacy on the internet." Too vague; doesn't say *whose* information or *what kind*, names no principles, and wrongly limits it to "the internet". 0–1 marks.

✓ A strong answer

"The *Privacy Act 1988* (Cwlth) protects the **personal information of individuals** — data that identifies or could identify a person. It contains the **13 Australian Privacy Principles (APPs)**, which set out how organisations must collect, use, secure and disclose that information."

How the marks are awarded

- 1 mark — identifies it protects **personal information of individuals**.
- 1 mark — names the **Australian Privacy Principles (APPs)** (accept "13 APPs").

Q2. Explain · 3 marks

A fitness app asks every new user for their full legal name before they can simply view a public workout library. Explain how this relates to APP 2, and what the app should do.

✗ A weak answer

"They shouldn't ask for your name because of privacy." Names no principle, no reasoning about whether identification is *needed*, no remedy. 1 mark at most.

✓ A strong answer

APP 2 (anonymity & pseudonymity) gives users the option to deal with an organisation anonymously or under a pseudonym where lawful and practical. Viewing a *public* library doesn't require identifying the user, so demanding a full legal name is unnecessary. The app should let users browse **anonymously** (or with an optional pseudonym/account) and only request identity when a feature genuinely needs it.

How the marks are awarded

- 1 — names **APP 2** / the anonymity-pseudonymity option.
- 1 — reasons that identification is **not necessary/practical** for browsing a public library.
- 1 — states the remedy: allow **anonymous/pseudonymous** access.

Q3. Apply · 4 marks

A school collected parent email addresses to send report cards. The marketing team now wants to use that list to advertise the school fete to those parents. Using APP 6, analyse whether this is allowed and identify one condition under which it could be.

✗ A weak answer

"No, that's spam and it's against the law." Right instinct, no APP 6 reasoning, no primary/secondary purpose language, and no condition given. Caps low.

✓ A strong answer

Under **APP 6**, personal information may only be used or disclosed for the **primary purpose** it was collected for. The emails were collected to **send report cards**, so using them to advertise the fete is a **secondary purpose**. Parents may not reasonably expect marketing from a report-card list, so by default this is **not allowed**. It would become permissible if the school **obtained the parents' consent** for promotional emails (or the use fell within another APP 6 exception, such as a related purpose the parents would reasonably expect).

How the marks are awarded

- 1 — identifies the **primary purpose** (report cards).
- 1 — labels the marketing use as a **secondary purpose**.
- 1 — concludes it is **not allowed by default** under APP 6.
- 1 — gives a valid condition (**consent** / reasonable-expectation exception).

Q4. Describe · 4 marks

The PulseCheck spreadsheet contains students' stress responses linked to codes. Describe two reasonable steps that satisfy APP 11, justifying each against the sensitivity of the data.

✗ A weak answer

"Use a password and don't lose the file." One generic step, no justification, no mention of access control or disposal. Reads as a list, not reasoning.

✓ A strong answer

Step 1 — store on an access-controlled drive with MFA: because stress data is sensitive, limiting access to the project team with multi-factor authentication reduces the risk of **unauthorised access**, a core APP 11 requirement. **Step 2 — delete the raw coded responses after the assembly:** APP 11 requires destroying or de-identifying information once it's **no longer needed**; keeping sensitive stress data beyond the project's purpose creates ongoing, unnecessary risk.

How the marks are awarded

- 1+1 — two valid, distinct reasonable steps (access control/MFA, encryption, restricted sharing, secure disposal...).
- 1+1 — each step **justified against sensitivity/context** (not just stated). Award the disposal point only if it links to "no longer needed".

Revision checklist

- Principle — names a specific APP (2, 6 or 11) and the Act
- Example — uses the scenario's detail (purpose, sponsor, names)
- Link — states the consequence / what they must do instead
- Key term — uses "primary/secondary purpose", "consent" or "disclosure"